01_CODE_ALONG_LAB

Pintop | 2026 Training

CLASSROOM CODE-ALONG - Authorisation, RBAC & API Security (Backend Design & Engineering)

Pintop Technologies | Class 08 | Instructor and student companion

What we will produce

Recreate a documented excerpt from the **real project** (`app/Http/Middleware/BearerToken.php`), practise a small safe variation, verify using the complete app or appropriate tool, and record both success and failure evidence. Preserve the original project.

Why: A logged-in customer manages to change another customer's order by editing the id in a request. They were authenticated, but not authorised. Today we separate the two questions and give each user only the power they need.

1. Find and read the real file

`codebase/app/Http/Middleware/BearerToken.php`

The excerpt is in `REFERENCE EXCERPT.php`. Its job is to give you something to type, trace and understand. It is not guaranteed to run on its own: it is part of a larger file. Do not overwrite project source with a fragment.

2. Set up the real project

```
cd "Backend Design & Engineering/codebase"
composer install
cp .env.example .env
php artisan key:generate
php artisan migrate --seed
php artisan serve --port=8000
```

3. Type in stages

Stage 1

Say: "I am writing a small section of the actual project. Look for the inputs and names; we will connect it with the next block."

```
use Symfony\Component\HttpFoundation\Response;
class BearerToken {
 public function handle(Request $request, Closure $next): Response {
  $token=$request->bearerToken();
```

Stage 2

Say: "I am writing a small section of the actual project. Look for the inputs and names; we will connect it with the next block."

```
  if (!$token) return response()->json(['message'=>'Authentication required','error'=>['code'=>'unauthorize
  $row=DB::table('api_tokens')->where('token_hash',hash('sha256',$token))->where('expires_at','>',now())->f
  if (!$row) return response()->json(['message'=>'Invalid or expired token','error'=>['code'=>'unauthorized
  $request->attributes->set('training_user_id',(int)$row->user_id);
```

Stage 3

Say: "I am writing a small section of the actual project. Look for the inputs and names; we will connect it with the next block."

```
        return $next($request);
    }
}
```

4. Complete these activities

1. **Trace the input from the login or token request to the verification routine.**
2. **Write down a failed authentication case and its expected status; do not display real secrets.**
3. **Add or adjust one local-only assertion, and repeat the success and failure case.**

5. Check, debug and record

```
php artisan route:list --path=api
php artisan test
```

Expected check: If the local app starts or its tests pass, capture evidence of the specific behaviour tied to this class, not merely an application startup. Test one failed or edge input too. Log the exact error if blocked.

6. Marking

- 4/20: explain concept and input/output in plain language
- 4/20: accurate typed or edited work
- 4/20: local proof and explanation
- 4/20: safe variation and wrong-case recovery
- 4/20: short documented submission

Lab ethics: no unapproved public scanning, no third-party tokens and no real banking customer data.